



FAMILLE OUTILS COMPAGNON

Comprendre la télémétrie Windows

*Event IDs, Sysmon et les six contrôles qui décident si
ton SOC voit — ou reste aveugle.*



On protège souvent un poste en le **durcissant** : mots de passe forts, mises à jour, pare-feu. C'est nécessaire, mais ça ne répond pas à une autre question, tout aussi vitale : **si une attaque réussit malgré tout, quelqu'un peut-il la voir ?**

Un poste durci mais **silencieux** reste un angle mort. Toute la détection moderne — Wazuh, Splunk, Sentinel, ELK — repose sur une matière première : la **téléométrie** que Windows génère sur lui-même. Si l'événement n'est pas enregistré **à la source**, aucun SIEM, aussi bon soit-il, ne pourra le détecter.

C'est une **chaîne**. Chaque maillon dépend du précédent. La supervision (Wazuh) est le dernier maillon, pas le premier : il ne fait que transporter ce que les maillons d'avant ont produit.



Wazuh = le maillon 5. Il transporte ; il ne crée rien.

Si les maillons 1 à 4 sont absents, il n'y a rien à transporter.

La chaîne de visibilité : cinq maillons, plus la rétention en filigrane.



L'idée à retenir : ce guide explique **chaque maillon** — ce qu'il capture, pourquoi il compte, ce que le SOC perd sans lui, et pourquoi Windows ne l'active pas tout seul.



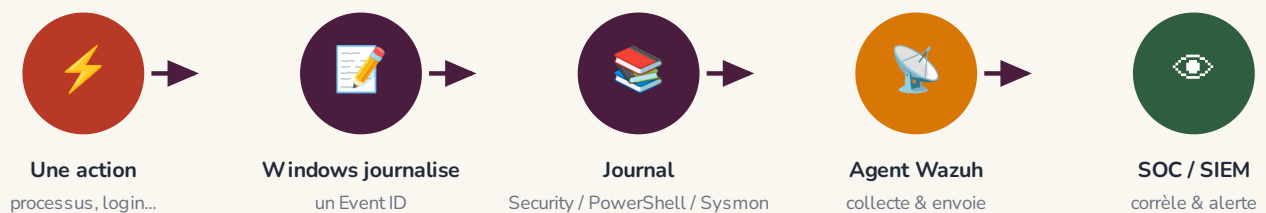
Comment Windows raconte ce qu'il fait

Windows consigne ce qui se passe sous forme d'**événements**, rangés dans des **journaux**. Chaque type d'événement porte un numéro, l'**Event ID**, qui dit de quoi il s'agit. **4624** = une session s'est ouverte. **4688** = un processus a démarré. **4104** = un bloc de script PowerShell a été exécuté.

Trois journaux nous intéressent particulièrement :

- Le journal **Security** — sessions, comptes, processus, politique d'audit.
- Le journal **PowerShell/Operational** — les scripts exécutés.
- Le journal **Sysmon/Operational** — la télémétrie fine ajoutée par Sysmon.

Mais générer l'événement n'est que le début. Pour qu'il serve à la détection, il doit voyager jusqu'au SOC :



Chaque maillon manquant brise le trajet : tout ce qui suit ne reçoit rien.

Le trajet d'un événement, de l'action jusqu'à l'alerte du SOC.

Chaque étape est un point de rupture possible. Si Windows ne génère pas l'événement, ou si le journal l'a déjà écrasé, ou si aucun agent ne le collecte — la chaîne est brisée, et le SOC ne saura jamais.



Pourquoi rien n'est activé par défaut

Si ces capteurs sont si utiles, pourquoi Windows ne les active-t-il pas d'office ? Ce n'est pas un oubli — c'est un choix de conception, pour quatre raisons légitimes.

1. Le volume

Auditer chaque processus, chaque bloc de script, chaque connexion réseau produit **énormément** d'événements. Sur un poste familial non supervisé, c'est du bruit qui remplit le disque pour rien.

2. La vie privée

La ligne de commande est journalisée **en clair** et devient lisible par quiconque accède au journal de sécurité. Elle peut contenir des mots de passe ou des données sensibles — un vrai sujet sur une machine partagée.

3. La compatibilité & la neutralité

Microsoft livre une configuration **minimale et neutre**, valable du poste familial au serveur, et laisse à l'administrateur le soin d'activer ce dont son contexte a besoin.

4. Certains ne sont même pas inclus

Sysmon n'est pas un composant de Windows : c'est un outil séparé à installer. Par défaut, ce maillon est tout simplement **absent**.



La bonne nouvelle : ce qui est désactivé par défaut peut être activé proprement, au bon niveau. C'est tout l'objet de la famille huntReady — rendre un poste audible **volontairement**, sans le casser.



1. La politique d'audit avancée

4688 4624 4625 4720 4719 1102 4776

Ce que c'est

La politique d'audit décide **quels événements de sécurité Windows accepte d'écrire** dans son journal Security. C'est le robinet de la source : si une action n'est pas auditée, elle a bien lieu, mais elle ne laisse **aucune trace**. On cible des familles d'événements à forte valeur :

Pourquoi ce contrôle, précisément

C'est le **tout premier maillon** de la chaîne. Toute la détection en dépend : aucun outil en aval, pas même Wazuh, ne peut voir un événement qui n'a jamais été généré. Activer les bonnes sous-catégories, c'est ouvrir les yeux de Windows.

Famille d'événements	Event IDs
Création de processus	4688
Ouverture / échec / fermeture de session	4624 4625 4634
Gestion des comptes (création, suppression, groupes)	4720 4726 4732
Changement de la stratégie d'audit / journal effacé	4719 1102
Validation des identifiants	4776

Sans lui — le SOC est aveugle aux comptes et aux sessions

Un attaquant crée un compte administrateur discret pour conserver son accès, puis efface le journal pour brouiller les pistes. Sans audit de la **gestion des comptes** (4720/4732) ni de l'**effacement du journal** (1102), ce porte dérobée n'apparaît nulle part : l'intrusion reste totalement invisible.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1136 · Création de compte

T1098 · Manipulation de compte

T1110 · Force brute

T1070.001 · Effacement des journaux

T1021 · Services distants

Pourquoi ce n'est pas activé par défaut

L'audit des sessions est souvent actif par défaut, mais la **création de processus**, la **gestion des comptes**, le **changement de stratégie** et la **validation des identifiants** sont généralement désactivés. Microsoft garde une configuration neutre pour limiter le volume de journaux sur les postes non supervisés.



2. La ligne de commande dans l'événement 4688

4688

Ce que c'est

Quand un processus démarre, Windows peut écrire l'événement **4688**. Par défaut, celui-ci ne contient que le **nom de l'exécutable**. Une option distincte ajoute la **ligne de commande complète** : les arguments réellement passés au programme.

Pourquoi ce contrôle, précisément

Le nom seul ne raconte rien. « powershell.exe a démarré » est parfaitement banal ; « powershell.exe -enc <base64> » révèle une commande encodée et suspecte. C'est la différence entre une caméra qui filme une porte qui s'ouvre, et une caméra qui filme **qui entre et ce qu'il transporte**.

4688 sans ligne de commande

Nouveau processus :

powershell.exe

Ligne de commande :

(vide)

✗ Le SOC voit une porte s'ouvrir, pas ce qui entre.

4688 avec ligne de commande

Nouveau processus :

powershell.exe

Ligne de commande :

-enc SQBFAFgAIAAoAE4AZQB3...

✓ Le SOC voit une commande encodée suspecte. Il peut réagir.

Le même événement 4688, sans puis avec la ligne de commande.

Sans lui — le SOC voit l'outil, jamais l'intention

Un one-liner PowerShell encodé télécharge et exécute une charge directement en mémoire. Sans la ligne de commande, le SOC ne voit qu'un « powershell.exe » anodin parmi des centaines. Avec elle, il voit la commande malveillante décodable et peut lever une alerte.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1059 · Interpréteur de commandes

T1059.001 · PowerShell

T1027 · Fichiers obfusqués

T1218 · Exécution via binaires légitimes (LOLBins)

Pourquoi ce n'est pas activé par défaut

Désactivée par défaut notamment pour la **vie privée** : la ligne de commande est écrite **en clair** dans le journal et devient lisible par toute personne pouvant lire les événements de sécurité — elle peut contenir des mots de passe ou des données sensibles. S'ajoute la question du volume.



3. La journalisation PowerShell

4104

4103

400

600

Ce que c'est

PowerShell est l'outil n°1 des attaques « sans fichier ». Trois couches le rendent visible : la **journalisation des blocs de script** (event 4104) enregistre le code réellement exécuté, **désobfusqué** ; la **journalisation des modules** (4103) détaille le pipeline ; la **transcription** archive des sessions entières.

Pourquoi ce contrôle, précisément

Le 4104 est la pièce maîtresse. Même si l'attaquant encode ou obfusque son script, PowerShell le journalise **une fois décodé**, juste avant l'exécution. C'est très souvent la **seule trace** d'une attaque qui ne touche jamais le disque.

Sans lui — le SOC ne voit pas le code qui s'exécute en mémoire

Un « download cradle » du type **IEX (New-Object Net.WebClient).DownloadString(...)** exécute du code en mémoire, sans jamais créer de fichier. L'antivirus n'a rien à analyser, le 4688 ne voit que « powershell.exe ». Seul le 4104 capture le script malveillant lui-même.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1059.001 · PowerShell

T1027 · Obfuscation

T1620 · Chargement de code réflexif

T1105 · Transfert d'outils

Pourquoi ce n'est pas activé par défaut

Désactivée par défaut essentiellement pour le **volume** : PowerShell est très bavard et journaliser chaque bloc de script produit beaucoup d'événements. C'est un réglage que l'on active volontairement par stratégie sur les postes que l'on souhaite superviser.



4. Sysmon

1 3 8 10 11 12 13 14 22

Ce que c'est

Sysmon (Microsoft Sysinternals) n'est **pas natif** à Windows : c'est un complément qui ajoute une télémétrie que le système ne produit pas seul, dans son propre journal :

Pourquoi ce contrôle, précisément

Windows seul ne voit ni l'**injection de code**, ni l'**accès à la mémoire de LSASS** (où vivent les identifiants), ni les **requêtes DNS**. Sysmon comble ces angles morts : c'est le maillon « enrichissement ».

Event	Sysmon capture	Pourquoi c'est précieux
1	Création de processus (+ hash, parent, ligne de commande)	Plus riche que le 4688 natif
3	Connexion réseau	Détecter le Command & Control
7	Chargement de DLL	Détecter le détournement de bibliothèques
8	CreateRemoteThread	Injection de code dans un autre processus
10	Accès à un processus (mémoire)	Vol d'identifiants via LSASS
11	Création de fichier	Dépôt de charges malveillantes
12-14	Modifications du registre	Persistance, désactivation de défenses
22	Requête DNS	C2 et exfiltration par DNS

Sans lui — le SOC ne voit pas le vol d'identifiants

Un outil comme Mimikatz lit la mémoire du processus **lsass.exe** pour en extraire des identifiants. **Aucun** événement Windows natif ne le signale. L'événement Sysmon **10** (accès à lsass.exe) est le signal n°1 de cette attaque — sans Sysmon, elle est muette.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1003.001 · Vidage de LSASS

T1055 · Injection de processus

T1071 · C2 sur protocole applicatif (DNS)

T1546 · Exécution déclenchée par événement

Pourquoi ce n'est pas activé par défaut

Sysmon n'est tout simplement **pas inclus** dans Windows : il faut l'installer et lui fournir une configuration. Par défaut, ce maillon est donc absent — c'est le rôle de l'assistant **huntReady-sysmon**.



Ce que c'est

Chaque journal Windows a une **taille maximale**. Une fois plein, les **anciens événements sont écrasés** par les nouveaux. Le journal Security est souvent petit par défaut (de l'ordre de 20 Mo), ce qui peut ne représenter que **quelques heures** d'historique sur un poste actif.

Pourquoi ce contrôle, précisément

Générer les bons événements ne sert à rien s'ils **disparaissent** avant d'être collectés. Ce maillon est transversal : il conditionne la **survie** de tout ce que les autres produisent. Un bon historique, c'est la mémoire du poste.

Sans lui — le SOC enquête sur des preuves déjà effacées

Une attaque a lieu vendredi soir ; l'analyste enquête lundi. Si le journal a « tourné » entre-temps, les preuves sont écrasées : l'attaque devient **invisible rétroactivement**. Pire, un attaquant peut volontairement **noyer** les journaux sous du bruit pour forcer leur rotation et effacer ses traces.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1070.001 · Effacement des journaux (par saturation)

T1562 · Affaiblissement des défenses

Pourquoi ce n'est pas activé par défaut

Les tailles sont petites par défaut pour **économiser l'espace disque** sur des postes qui, par défaut, ne sont pas supervisés. Sur un poste raccordé à un SOC, il faut les agrandir pour conserver assez d'historique entre deux collectes.



5. Wazuh, et pourquoi tout le reste en est le prérequis

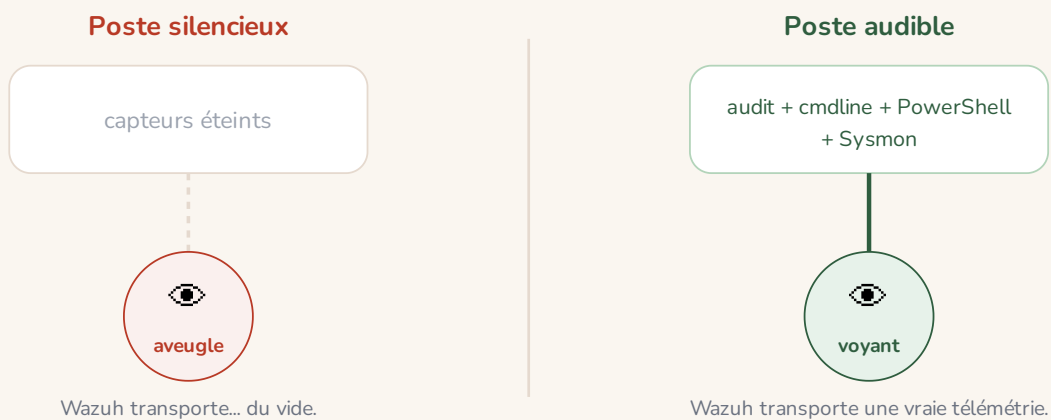


Ce que c'est

L'agent **Wazuh** collecte les journaux du poste et les **envoie** au manager, où ils sont corrélés, alertés et conservés. C'est le maillon qui relie enfin le poste au SOC.

Pourquoi ce contrôle, précisément

Point essentiel : Wazuh **ne crée aucune donnée**. Il **transporte** ce qui existe déjà. Si la génération, la capture, la journalisation et l'enrichissement n'ont pas eu lieu, l'agent transporte... du vide. C'est exactement pour cela que **les quatre premiers maillons sont un prérequis** : installer Wazuh sur un poste silencieux donne un SOC qui reçoit beaucoup de messages... tous vides.



À gauche, Wazuh transporte le vide. À droite, une vraie télémétrie atteint le SOC.

Sans lui — installer Wazuh ne suffit pas

Une organisation déploie Wazuh partout et se croit protégée. Mais sur des postes où l'audit, la ligne de commande, PowerShell et Sysmon n'ont jamais été activés, le SIEM reçoit un flux pauvre : il **ne peut pas détecter** ce que les postes n'ont jamais journalisé. La centralisation sans génération, c'est un télescope braqué sur une pièce éteinte.

TECHNIQUES MITRE ATT&CK QUI DEVIENNENT INVISIBLES

T1562 · Affaiblissement des défenses (visibilité)

Couverture de détection incomplète

Pourquoi ce n'est pas activé par défaut

L'agent n'est pas installé par défaut : c'est une démarche volontaire de supervision. Mais surtout, il n'a de valeur que **posé en dernier**, une fois la source de télémétrie ouverte — d'où l'ordre de la chaîne.



Chaque maillon ouvre un angle de vision. Ensemble, ils donnent au SOC une image complète du poste. Voici la synthèse de ce qui disparaît quand l'un manque :

Contrôle	Event IDs clés	Sans lui, le SOC ne voit pas...
Politique d'audit	4688 4624 4720 1102	comptes créés, sessions, journaux effacés
Ligne de commande 4688	4688	la commande réellement exécutée
Journalisation PowerShell	4104 4103	le code en mémoire, même obfusqué
Sysmon	1 8 10 22	injection, vol de LSASS, C2 par DNS
Capacité des journaux	—	les preuves déjà écrasées
Centralisation (Wazuh)	—	rien, si les autres maillons sont absents

L'ordre compte

On rend d'abord le poste **capable de parler** (maillons 1 à 4, plus la rétention), puis on le **raccorde** au SOC (maillon 5, Wazuh). Installer la centralisation en premier, sur un poste silencieux, donne un SIEM qui reçoit du vide.



Pour passer à la pratique : l'audit **huntReady.ps1** mesure où en est ton poste, **huntReady-fix.ps1** active les maillons 1 à 4, et **huntReady-sysmon.ps1** pose l'enrichissement. Le maillon 5 se branche ensuite avec Wazuh.

huntReady-compagnon · DOUKAKAS Yeni